COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.5 · Endpoint Security

Mestre CyberSec · **Aula 4.5 — Endpoint Security** (9:25) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Endpoint: EDR (behavior + isolate + revert — evolution do antivírus); posture assessment (checa o dispositivo antes de dar acesso — MDM, AV, patch); remediation; NAC (802.1X + postura).

💡 Highlights que a prova CompTIA cobra

- EDR: vê o comportamento e RESPONDE (isola o host)
- Posture assessment: o 'exame de saúde' antes de conectar à rede

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'detects malicious behavior on endpoint and can isolate'=EDR

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.5 — Endpoint Security)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Detecção e Resposta de Endpoint (EDR)
Solução avançada de segurança de endpoint que monitora continuamente o comportamento do endpoint, detecta atividades maliciosas por meio de análise comportamental e pode isolar automaticamente hosts comprometidos e revertê-los a um estado limpo. Representa a evolução do antivírus tradicional para uma ferramenta de segurança proativa baseada em comportamento.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'detects malicious behavior on endpoint and can isolate the host' = EDR (NOT antivirus). EDR is the modern evolution that responds; legacy AV only detects known signatures.*

• Avaliação de Postura (N/A)
Verificação de saúde realizada em um endpoint antes de conceder acesso à rede, confirmando que o dispositivo atende a requisitos de segurança como antivírus atualizado, patches atuais e inscrição no MDM. É um componente central do Network Access Control (NAC).

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'health check before connecting to the network' = Posture Assessment. Often paired with NAC; the endpoint must pass posture checks or be sent to remediation.*

• Controle de Acesso à Rede (NAC)
Framework de segurança que restringe o acesso à rede com base na identidade, autenticação e postura de segurança do dispositivo, comumente usando 802.1X para autenticação baseada em porta. Dispositivos não conformes são negados, colocados em quarentena ou enviados a uma rede de remediação.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: '802.1X + posture assessment' = NAC. NAC = port-based access control + health checks; answers are about controlling WHO can connect and WHAT state they must be in.*

• IEEE 802.1X
Padrão de controle de acesso à rede baseado em porta que autentica dispositivos que se conectam a uma LAN ou WLAN antes de permitir acesso total à rede, usando um supplicant (cliente), autenticador (switch/AP) e servidor de autenticação (tipicamente RADIUS). É o protocolo base das implementações de NAC.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'port-based network authentication' = 802.1X. Remember the trio: Supplicant + Authenticator + Authentication Server (RADIUS). Used by NAC to enforce access control.*

• Gerenciamento de Dispositivos Móveis (MDM)
Solução de gerenciamento centralizado usada para aplicar políticas de segurança em endpoints móveis (smartphones, tablets, laptops), incluindo criptografia do dispositivo, wipe remoto, controle de aplicativos e garantia

de conformidade de patches do SO para avaliação de postura.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'managing and enforcing policy on mobile devices / BYOD' = MDM. MDM = device-side enforcement; MAM (Mobile Application Management) = app-side only.*

• Remediação (N/A)

Processo de corrigir deficiências de segurança em um endpoint não conforme, como instalar patches ausentes, atualizar assinaturas de antivírus ou habilitar um firewall baseado em host, antes de conceder acesso completo à rede. Frequentemente implementado via VLAN de quarentena.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'fix the endpoint to meet policy before allowing access' = Remediation. A non-compliant device gets sent to a remediation network/VLAN, NOT denied entirely (unless no fix is possible).*

• Rede de Quarentena (VLAN em Quarentena) (N/A)

Segmento de rede isolado e restrito onde endpoints não conformes ou suspeitos são colocados para passar por remediação ou análise forense, com acesso limitado apenas a servidores de atualização e recursos de segurança. Usado pelo NAC e ações de resposta do EDR.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'isolated network for non-compliant or infected devices' = Quarantine Network. EDR isolates hosts here, and NAC sends posture-failed devices here for remediation.*

• Isolamento de Host (N/A)

Ação de resposta do EDR que desconecta um endpoint comprometido da rede (ou o restringe a uma VLAN de quarentena) para evitar movimento lateral e propagação adicional de malware, preservando o dispositivo para investigação forense.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'EDR response that disconnects a compromised endpoint' = Host Isolation. This is the key differentiator: AV detects, EDR detects AND responds (isolates/reverts).*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Antivírus Tradicional vs NGAV vs EDR (Do Álbum de Fotos à Caixa-Preta Forense)

🏠 **Analogia Intuitiva:** O antivírus tradicional é o segurança de shopping com um caderninho de fotos de criminosos procurados (banco de assinaturas antigas); se um ladrão com máscara nova entrar, o segurança não faz nada. O NGAV (Next-Gen AV) é o psicólogo comportamental que observa as atitudes suspeitas: mesmo sem foto do sujeito, se ele começar a forçar maçanetas e pular balcões (heurística comportamental e aprendizado de máquina), o NGAV o imobiliza na hora. Já o EDR (Endpoint Detection and Response) é a central de inteligência da polícia com câmeras de alta definição e caixas-pretas dentro de cada loja: além de deter o suspeito, ele rastreia de onde ele veio, quais maçanetas ele tocou, grava cada passo dele na memória e permite que o xerife central tranque o shopping inteiro com o toque de um botão.

🔍 **Causa Raiz / Por que foi criado:** Ataques modernos utilizam malwares polimórficos gerados dinamicamente e técnicas 'fileless' (sem gravar arquivos em disco, rodando direto na memória via utilitários legítimos do SO como PowerShell), tornando o antivírus clássico baseado em assinaturas totalmente cego.

🛡️ **Visão do Auditor de GRC:** Fiscalização da presença obrigatória de agentes EDR gerenciados em 100% dos computadores e servidores corporativos; auditoria da retenção mínima de telemetria de endpoint no SIEM/Data Lake e garantia de que a resposta automática de remediação esteja ativada.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'endpoint security platform continuously capturing process execution, network connections, and enabling remote isolation and remediation' = EDR. 'Antivirus relying on AI and machine learning to stop unknown zero-day malware' = NGAV.

📌 Isolamento de Máquina & Quarentena de Rede (A Comporta Biológica)

🏠 **Analogia Intuitiva:** Imagine um surto de um vírus biológico altamente contagioso e letal em uma enfermaria de hospital. A primeira providência médica não é tentar limpar o chão ou dar remédio ao paciente com calma; é fechar imediatamente as comportas de ar herméticas e trancar a porta de vidro do quarto (quarentena biológica estrita) para impedir que o vírus se espalhe pelo sistema de ventilação para o restante do hospital. O isolamento de máquina via EDR faz exatamente isso: corta instantaneamente toda a comunicação do computador infectado com a rede local e a internet, mantendo apenas um túnel exclusivo e seguro com o console do analista de segurança.

🔍 **Causa Raiz / Por que foi criado:** Ransomwares e grupos criminosos avançados executam movimentos laterais automáticos em segundos após a invasão inicial, saltando de estação em estação para criptografar servidores de arquivos corporativos.

🛡️ **Visão do Auditor de GRC:** Existência de autorização formal documentada na Política de Resposta a Incidentes permitindo que analistas do SOC isolem computadores imediatamente ao detectar ransomware ou beaconing ativo sem necessidade de aprovação da diretoria de negócios.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'security analyst detects an active ransomware infection spreading across internal workstations; what is the IMMEDIATE next step?' = Isolate the affected host from the network. Pegadinha: NUNCA desligue o equipamento da tomada (destrói evidências de memória RAM).

📌 HIPS / HIDS (Host-based Intrusion Prevention & Detection Systems)

🏠 **Analogia Intuitiva:** Um guarda-costas pessoal exclusivo que fica em pé colado nas suas costas dentro da sua sala de trabalho. Ele não fica apenas vigiando o portão da rua (como faz o firewall de rede); ele fica dentro da sua sala prestando atenção se alguém tentar abrir a sua gaveta com documentos sigilosos, trocar sua caneta por uma com ponta envenenada ou modificar o contrato em cima da sua mesa. Se o guarda-costas for HIPS (Prevention), ele segura com força o pulso do invasor antes do golpe; se for HIDS (Detection), ele apenas grita no rádio avisando a recepção.

🔍 **Causa Raiz / Por que foi criado:** O tráfego de rede corporativo moderno é massivamente criptografado por TLS, tornando os sistemas de inspeção de rede (NIDS) cegos para comandos maliciosos executados diretamente dentro do sistema operacional do host.

🛡️ **Visão do Auditor de GRC:** Fiscalização da implantação de HIPS em servidores contendo bancos de dados confidenciais e ambientes de processamento de pagamentos (PCI-DSS); auditoria periódica de regras de bloqueio e descarte de falsos positivos.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'software agent running on a server that actively blocks unauthorized system modifications, suspicious registry changes, and buffer overflows' = HIPS. Distrator: HIDS apenas detecta e alerta; HIPS ativamente bloqueia.

📌 Integridade de Arquivos (FIM) & Listas de Permissão de Aplicativos (Allowlisting)

🏠 **Analogia Intuitiva:** Imagine tirar uma foto de alta resolução com carimbo de cera de todas as prateleiras de uma farmácia de manipulação de venenos controlados após a auditoria sanitária (baseline). Toda manhã, o farmacêutico-chefe compara o estado atual com a foto original. Se um único frasco tiver mudado de posição ou o selo tiver sido rompido, soa o alarme de adulteração (FIM). E na porta de entrada da farmácia há uma lista com fotos dos únicos três produtos autorizados a entrar no estoque; qualquer outro pacote que chegue é barrado imediatamente na calçada (Application Allowlisting).

🔍 **Causa Raiz / Por que foi criado:** Invasores avançados substituem binários legítimos do sistema operacional (como DLLs e utilitários de autenticação) por versões modificadas contendo portas dos fundos (backdoors) indetectáveis por antivírus comuns.

🛡️ **Visão do Auditor de GRC:** Implementação mandatória de FIM em arquivos de configuração críticos e diretórios de sistema conforme exigido pelo PCI-DSS (Requisito 11.5); imposição de políticas de Application Allowlisting (AppLocker/Windows Defender Application Control) em estações de alto risco.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'verifying whether critical system binaries or web server configuration files have been modified using cryptographic hashes' = File Integrity Monitoring (FIM). 'Preventing unauthorized executables from running by permitting only pre-approved software hashes' = Application Allowlisting.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Plataforma de endpoint que monitora continuamente telemetria comportamental, detecta anomalias e permite isolamento remoto de hosts	**EDR (Endpoint Detection and Response)**
Antivírus moderno que emprega inteligência artificial e aprendizado de máquina para interceptar ameaças de dia zero sem assinaturas	**Antivírus de Nova Geração (NGAV)**
Ação imediata de contenção executada pelo analista do SOC ao detectar infecção ativa por ransomware em uma estação de trabalho	**Isolamento de Rede do Host (Host Isolation)**
Agente instalado diretamente no servidor que monitora chamadas de sistema e bloqueia ativamente ataques em tempo real	**HIPS (Host-based Intrusion Prevention System)**
Ferramenta de segurança que compara periodicamente hashes criptográficos de arquivos críticos para alertar sobre modificações não autorizadas	**Monitoramento de Integridade de Arquivos (FIM)**
Controle corporativo que impede a execução de qualquer software que não esteja explicitamente homologado em uma lista de hashes aprovados	**Lista de Permissão de Aplicativos (Application Allowlisting)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança recebe um alerta do EDR indicando que o processo de um editor de texto em uma estação de trabalho gerou um shell de comando que está baixando um payload codificado de um IP externo desconhecido. O usuário está trabalhando ativamente na máquina, e o analista quer impedir que o ataque se espalhe para outros hosts, preservando as evidências voláteis e mantendo a capacidade de se comunicar com o endpoint pelo console do EDR. Qual ação o analista deve tomar?

A) Desabilitar imediatamente a conta do usuário no Active Directory em todos os endpoints corporativos gerenciados

B) Reinstalar a imagem da estação de trabalho para remover o código malicioso mantendo telemetria e monitoramento contínuos

C) Isolar o host da rede usando o console do EDR, mantendo o canal de gerenciamento

D) Bloquear o endereço IP externo no firewall de perímetro em todos os clusters híbridos locais e em nuvem

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa implanta IEEE 802.1X em todas as portas de switch com fio, com um servidor RADIUS. O notebook de um funcionário se autentica com sucesso usando um certificado válido, mas a avaliação de postura (posture assessment) informa que as assinaturas do antivírus estão 45 dias desatualizadas e que o sistema operacional não tem patches críticos. A política corporativa exige dispositivos em conformidade antes de conceder acesso total à rede. O que a solução de NAC deve fazer?

A) Mover o dispositivo para uma VLAN de quarentena que permite acesso apenas a servidores de patch e de atualização de antivírus

B) Rejeitar a autenticação e bloquear permanentemente o endereço MAC do dispositivo eliminando pontos únicos de falha operacional

C) Conceder acesso total à rede e registrar a violação de postura para revisão posterior em todos os clusters híbridos locais e em nuvem

D) Revogar o certificado do dispositivo e exigir novo registro sem interromper a disponibilidade das cargas de produção

QUESTÃO 3 · CENÁRIO DE EXAME

Um ransomware começa a criptografar arquivos em várias estações de trabalho e em um servidor de arquivos. O console do EDR mostra que o processo malicioso ainda está em execução e acabou de começar a criptografar arquivos em um compartilhamento de rede. Os administradores precisam interromper a criptografia imediatamente e restaurar os arquivos afetados sem pagar resgate. Qual ação eles devem tomar?

A) Bloquear o hash do arquivo malicioso e atualizar as assinaturas do antivírus em todos os hosts eliminando pontos únicos de falha operacional

B) Usar o EDR para isolar os hosts afetados e, em seguida, aplicar o recurso de rollback para restaurar os arquivos modificados pelo processo malicioso

C) Encerrar o alerta do EDR e restaurar o servidor de arquivos a partir do backup mais recente sem interromper a disponibilidade das cargas de produção

D) Habilitar criptografia de disco completo nas estações de trabalho afetadas aplicando menor privilégio e reduzindo superfícies de ataque

QUESTÃO 4 · CENÁRIO DE EXAME

Uma organização usa uma solução de MDM para gerenciar smartphones e tablets corporativos. Antes de um dispositivo poder acessar o e-mail corporativo, o MDM realiza uma avaliação de postura. Um dispositivo que tenta se registrar informa que a criptografia de todo o dispositivo está desabilitada e que a versão do sistema operacional está três versões principais atrasada. Qual ação o MDM deve tomar?

A) Apagar o dispositivo e exigir que o usuário o registre novamente em todos os clusters híbridos locais e em nuvem

B) Permitir o acesso ao e-mail, mas restringir o usuário somente à leitura sem interromper a disponibilidade das cargas de produção

C) Emitir um novo certificado de cliente e permitir o acesso aplicando menor privilégio e reduzindo superfícies de ataque

D) Negar o acesso ao e-mail corporativo e aplicar uma política de conformidade exigindo criptografia e atualização do sistema operacional

QUESTÃO 5 · CENÁRIO DE EXAME

Uma planta industrial usa 300 sensores IoT não gerenciados que não podem executar agentes de endpoint. Um sensor foi identificado se comunicando com um endereço IP malicioso conhecido. A equipe de segurança quer conter o dispositivo enquanto o fornecedor investiga, mas o sensor ainda precisa conseguir alcançar o servidor de atualização interno do fornecedor. Qual controle atende melhor a esse requisito?

A) Atribuir a porta de switch do sensor a uma VLAN de quarentena com uma ACL que permite tráfego apenas para o servidor de atualização interno

B) Implantar um agente EDR no sensor e usar o isolamento de host aplicando menor privilégio e reduzindo superfícies de ataque

C) Bloquear o endereço IP malicioso no firewall de perímetro através de pipelines automatizados de configuração

D) Alterar o servidor DNS do sensor para o resolvedor interno assegurando conformidade rigorosa de retenção de logs

QUESTÃO 6 · CENÁRIO DE EXAME

Um engenheiro de rede está implantando 802.1X no campus corporativo. O projeto inclui software cliente em cada notebook, os switches de acesso e um servidor RADIUS. Durante os testes, o engenheiro precisa confirmar qual componente encaminha as credenciais de autenticação ao servidor RADIUS e controla o estado da porta. Qual componente desempenha esse papel?

A) O software cliente atuando como supplicant

B) O servidor RADIUS atuando como servidor de autenticação

C) O switch de acesso atuando como autenticador

D) A autoridade certificadora atuando como autoridade de registro

QUESTÃO 7 · CENÁRIO DE EXAME

Um prestador de serviços remoto se conecta à VPN corporativa. A solução de NAC realiza uma verificação de postura do host e descobre que o firewall do sistema operacional do endpoint está desabilitado. A política da empresa exige que dispositivos não conformes sejam corrigidos antes de acessar recursos internos. Qual ação o NAC deve tomar?

A) Encerrar a sessão VPN e bloquear permanentemente a conta do prestador através de pipelines automatizados de configuração

B) Permitir acesso total, mas habilitar a gravação da sessão do prestador assegurando conformidade rigorosa de retenção de logs

C) Desabilitar automaticamente as regras de firewall corporativas para essa sessão utilizando perfis padronizados de automação de segurança

D) Redirecionar o endpoint para um portal de remediação que fornece a configuração ou as ferramentas necessárias e, em seguida, reavaliar a conformidade

QUESTÃO 8 · CENÁRIO DE EXAME

Um usuário recebe um documento que explora uma vulnerabilidade em um aplicativo de escritório, e o código malicioso é executado inteiramente na memória, sem gravar um arquivo em disco. O antivírus tradicional não gera alerta porque o payload não tem assinatura conhecida. Qual tecnologia tem maior probabilidade de detectar essa atividade?

A) Um scanner antivírus baseado em assinaturas após a atualização dos seus arquivos de definição assegurando conformidade rigorosa de retenção de logs

B) O EDR, ao correlacionar comportamento anômalo de processos, como um aplicativo de escritório gerando um mecanismo de script

C) Um firewall de host, ao bloquear tráfego de entrada na porta 445 prevenindo desvios não autorizados de configuração nos nós

D) A criptografia de disco completo, ao validar a cadeia de inicialização em todos os endpoints corporativos gerenciados

QUESTÃO 9 · CENÁRIO DE EXAME

Um alerta do EDR em uma estação de trabalho do setor de marketing é confirmado como um trojan. O analista isola o host. O líder de resposta a incidentes quer determinar a causa raiz, remover o malware e garantir que o host seja confiável antes de retornar à rede. Qual sequência de ações atende melhor a esses objetivos?

A) Coletar artefatos forenses enquanto o host está isolado, reinstalar a imagem do endpoint, restaurar os dados do usuário e reconectá-lo à rede

B) Executar a verificação do antivírus, excluir o arquivo detectado e reconectar o host imediatamente prevenindo desvios não autorizados de configuração nos nós

C) Reconectar o host e monitorá-lo com o EDR por 24 horas antes de decidir em todos os endpoints corporativos gerenciados

D) Mover o host para uma VLAN diferente e redefinir a senha do usuário mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização permite que funcionários usem smartphones pessoais para e-mail corporativo por meio de um MDM. A política de segurança exige que os dispositivos estejam registrados, tenham bloqueio de tela e não estejam com root ou jailbreak. Um funcionário registra um dispositivo que informa estar com jailbreak. A verificação de postura do MDM falha. Qual ação a organização deve tomar?

A) Permitir o acesso porque o funcionário assinou o termo de uso aceitável prevenindo desvios não autorizados de configuração nos nós

B) Conceder acesso apenas a calendário e contatos em todos os endpoints corporativos gerenciados

C) Enviar o dispositivo ao console do EDR para isolamento de host mantendo telemetria e monitoramento contínuos

D) Negar o acesso ao e-mail corporativo até que o dispositivo seja restaurado para um estado suportado e sem jailbreak

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Isolar o host da rede usando o console do EDR, mantendo o canal de gerenciamento

O isolamento de host (host isolation) é uma ação de contenção do EDR que desconecta o endpoint da rede, mantendo intacto o canal de gerenciamento do EDR. Isso interrompe o movimento lateral e o tráfego de C2, preserva a memória volátil e os processos em execução para análise forense, e permite ao analista continuar coletando telemetria e enviando comandos. Desabilitar a conta do AD não interrompe o processo malicioso já em execução. Reinstalar a imagem destrói evidências e é uma etapa de remediação, não de contenção. Bloquear um único IP externo é facilmente contornado por algoritmos de geração de domínio ou nova infraestrutura e não contém o host.

Questão 2: Alternativa A — Mover o dispositivo para uma VLAN de quarentena que permite acesso apenas a servidores de patch e de atualização de antivírus

O dispositivo provou sua identidade, mas não sua saúde. Em uma implantação de NAC com avaliação de postura, a resposta padrão para um dispositivo autenticado, porém não conforme, é colocá-lo em uma VLAN de quarentena, um segmento de rede restrito que permite apenas acesso a recursos de remediação, como servidores de patch e de atualização de antivírus. Depois que o dispositivo atende à política de postura, ele é reavaliado e pode ser movido para a VLAN de produção. Rejeitar a autenticação ou revogar o certificado puniria um usuário válido, conceder acesso total viola a política, e bloquear permanentemente o endereço MAC é desnecessariamente disruptivo.

Questão 3: Alternativa B — Usar o EDR para isolar os hosts afetados e, em seguida, aplicar o recurso de rollback para restaurar os arquivos modificados pelo processo malicioso

O isolamento impede que o ransomware se espalhe para outros hosts e evita mais criptografia na rede, enquanto o recurso de rollback/revert do EDR restaura os arquivos modificados pelo processo malicioso ao estado anterior à criptografia. Juntos, eles contêm e recuperam rapidamente. Bloquear o hash é reativo e não ajuda arquivos já criptografados; restaurar do backup pode perder dados e demora muito mais; encerrar o alerta não faz nada para interromper o processo; e a criptografia de disco completo não restaura arquivos criptografados nem interrompe o ataque.

Questão 4: Alternativa D — Negar o acesso ao e-mail corporativo e aplicar uma política de conformidade exigindo criptografia e atualização do sistema operacional

Uma política de conformidade (postura) no MDM deve bloquear o acesso a recursos corporativos até que o dispositivo atenda aos requisitos de linha de base da organização, como criptografia do dispositivo e uma versão de SO suportada. O MDM pode enviar a configuração necessária ou direcionar o usuário para a remediação. Permitir e-mail somente leitura ou emitir um novo certificado ainda concede acesso a dados corporativos em um dispositivo não conforme. Um wipe completo é desproporcional para uma falha de postura no momento do registro e destrói os dados do usuário antes de tentar a remediação.

Questão 5: Alternativa A — Atribuir a porta de switch do sensor a uma VLAN de quarentena com uma ACL que permite tráfego apenas para o servidor de atualização interno

Uma VLAN de quarentena com ACLs é o controle apropriado para dispositivos que não podem executar um agente de endpoint. O switch pode atribuir dinamicamente a porta a uma VLAN restrita, onde o tráfego é limitado, por exemplo, apenas para o servidor de atualização interno do fornecedor, isolando o sensor comprometido do restante da rede. O isolamento de host do EDR exige um agente no dispositivo. Bloquear um único IP malicioso no perímetro não contém o dispositivo nem impede que ele alcance outros hosts internos. Alterar o servidor DNS não restringe seu acesso à rede.

Questão 6: Alternativa C — O switch de acesso atuando como autenticador

No 802.1X, os papéis são: o supplicant (software cliente no endpoint), o autenticador (o switch ou AP sem fio que controla a porta e retransmite mensagens EAP para o servidor de autenticação) e o servidor de autenticação (normalmente RADIUS, que valida as credenciais e retorna a decisão de autorização). O switch é o autenticador; ele não valida as credenciais em si, mas as encaminha ao RADIUS e aplica o estado da porta resultante.

Questão 7: Alternativa D — Redirecionar o endpoint para um portal de remediação que fornece a configuração ou as ferramentas necessárias e, em seguida, reavaliar a conformidade

A avaliação de postura tem como objetivo impor conformidade, e não punir permanentemente o usuário. A abordagem correta é manter o dispositivo em um estado restrito (quarentena), onde ele possa acessar um portal de remediação, orientar o usuário a habilitar o controle exigido, como o firewall do host, e reavaliar. Só depois que o dispositivo estiver em conformidade o acesso total deve ser concedido. Bloquear permanentemente a conta é excessivo, e permitir o acesso com monitoramento ou desabilitar as regras de firewall corporativas anula o propósito do controle.

Questão 8: Alternativa B — O EDR, ao correlacionar comportamento anômalo de processos, como um aplicativo de escritório gerando um mecanismo de script

O EDR usa análise comportamental e rastreamento de linhagem de processos, podendo sinalizar um aplicativo de escritório gerando um mecanismo de script, PowerShell ou um shell de comando que executa operações de rede ou de arquivo, mesmo quando nada é gravado em disco e nenhuma assinatura corresponde. O antivírus baseado em assinaturas não detecta payloads desconhecidos e sem arquivo. Uma regra de firewall de host na porta 445 e a criptografia de disco completo tratam de ameaças diferentes e não detectariam execução de código em memória.

Questão 9: Alternativa A — Coletar artefatos forenses enquanto o host está isolado, reinstalar a imagem do endpoint, restaurar os dados do usuário e reconectá-lo à rede

A boa prática após detectar malware é conter, preservar as evidências antes de alterar o sistema e então remediar. Como um trojan pode ter criado persistência, modificado arquivos do sistema ou deixado backdoors que uma simples exclusão pelo antivírus pode não remover, a remediação mais confiável para uma infecção confirmada é reinstalar a imagem do endpoint e restaurar os dados do usuário. Excluir um arquivo e reconectar imediatamente traz risco de reinfecção e não estabelece confiança. Monitorar um host sabidamente comprometido na rede de produção não é aceitável.

Questão 10: Alternativa D — Negar o acesso ao e-mail corporativo até que o dispositivo seja restaurado para um estado suportado e sem jailbreak

Um dispositivo com jailbreak ou root contorna os controles de segurança do sistema operacional, portanto não pode ser considerado confiável para armazenar dados de e-mail corporativo, mesmo com um perfil de MDM instalado. A avaliação de postura do MDM deve negar o acesso a recursos corporativos até que o dispositivo seja restaurado para um estado suportado e sem jailbreak. Um termo de uso aceitável ou acesso parcial, como calendário e contatos, ainda expõe dados corporativos a um dispositivo não confiável. O isolamento de host do EDR não se aplica, pois o dispositivo não é um endpoint gerenciado na rede corporativa.